SECURITY AND TRUST

Org Trust Layer: your own CA, fewer plugins

Your own certificate authority and signing keys, in your own Cloudflare and Xano accounts. **Identity and provenance in one layer, so plugins and connectors can move onto it.**

The Org Trust Layer gives an organization its own certificate authority and signing keys, running in its own Cloudflare and Xano accounts. Every system that talks to the ERP, the storefront or a partner proves who it is with a certificate from that CA, and every record that leaves (a consent choice, a product update, an order sent to SAP) carries a signature showing where it came from. With identity and provenance in one layer, much of the work done today by storefront plugins and paid connectors can move onto it.

What it replaces

TODAY	WITH THE ORG TRUST LAYER
Shared API keys and passwords for scanners, partners and services	A client certificate per device, service and agent, revocable one at a time
Public CA certificates on internal systems, installed by hand (including in SAP's `STRUST` trust store)	Certificates from the organization's own CA, issued from a request and renewed automatically; SAP still holds them in `STRUST`, but the root is imported once and renewals come from the same CA
Trust that breaks when a public CA is distrusted (eMudhra's emSign in 2026, Entrust in 2024)	Internal trust that depends only on the organization's own root
A consent cookie any script on the page can read or change	A consent choice signed under the organization's key and checked at the edge
No record of where a record came from or on what basis it was shared	Signed provenance on every outgoing record
A plugin or connector per job, each with its own script, data copy and subscription	One layer that holds the data once and routes it to each system

The organization's own certificate authority

The organization creates its root key offline, or in its own key store, and signs an issuing certificate that runs in its own Cloudflare account. The platform team never holds the root.

PROFILE	ISSUED TO	USED FOR
Device	Warehouse scanners, handhelds, kiosks	Mutual TLS to the edge; firmware downloads tied to a device certificate
Service	The service bus, ERP connectors, partner systems	Mutual TLS between systems, no shared secrets
Agent	AI and shopping agents	Proving which agent placed an order, under which mandate
Staff	People with elevated access	Signing approvals
SAP service	SAP application servers	RSA certificates sized for SAP's trust manager, imported once into `STRUST` and then renewed from the same CA

Public hostnames keep Cloudflare-managed certificates from public CAs, limited by a CAA record. The private CA is for machine identity, mutual TLS and signing, which public certificates can't do: they name only public domains, appear in public Certificate Transparency logs, and are moving to server authentication only.

What the keys sign

SIGNED	HOW	WHAT IT PROVES
Machine identity	Client certificates from the org CA	Which system made each call
PKI tokens	Short-lived tokens bound to a certificate, carrying the caller's permissions and how far back in history it may read	That a caller can do this, and only this, for this long
Consent cookies	The shopper's choice written as a short signed value, checked at the edge on every request, copied to the consent ledger with the key ID	The choice wasn't forged or edited in the browser, and which choice applied when data left
Data provenance	A signed note on every record sent to SAP, Dynamics, Klaviyo, Salesforce or Google: source system, consent state, region, time, payload hash, key ID	Where each record came from and on what basis it was shared
Transaction records	A signed, personal-data-free record per order, found by any ID it carries (order, payment, return, ERP document)	That the transaction happened as recorded, verifiable offline
SAP document ledger	Each document the layer creates in SAP, logged by type and signed, with a monthly count	How many licensable documents the integration created

Fewer plugins and connectors

Once identity, consent and the data plane sit in one layer, several plugin and connector jobs become routes the organization already runs. Each one moves only when its data can be exported and checked.

PLUGIN OR CONNECTOR	WHAT THE LAYER TAKES OVER	WHAT STAYS
Reviews app	Reviews stored in the organization's data plane, tied to verified orders, ratings sent to Google through the Merchant API	Loyalty or SMS features, if used, stay with the vendor or move separately
Consent management platform	Region-scoped banner, Shopify Customer Privacy API, Google Consent Mode signals, signed consent ledger	A Google-certified CMP where the site serves Google ads in the EEA or UK
Email and SMS sync app	Server-side events from the edge, only for profiles with marketing consent, using the organization's own API key	The email platform stays the sender
CRM connector apps	CRM events in through the edge; orders, cases and accounts written with the same identifier crosswalk as the ERP	CRM licences and per-org API limits
Integration bus licence	Queues and Workers route events between Shopify, feeds, the WMS and the ERP's own APIs	Cloudflare usage billing; the ERP's own licence terms

The layer also takes the Shopify app-token deadlines (expiring tokens from 1 January 2027, refused old tokens from 1 April 2027) and Google's Merchant API data shape off each plugin's to-do list, because the layer, not the plugin, holds the connection.

SAP and Dynamics: measured and licensed, not bypassed

The layer makes ERP licensing measurable. It doesn't remove it.

- **Documents created in SAP are counted.** Under SAP's Digital Access model, documents that outside systems create in SAP are licensed by count. The signed document ledger gives the organization its own count, by type, to check against SAP's.

- **AI stays on the organization's own data.** SAP's API Policy version 4 (April 2026) restricts third-party AI that plans or chains calls to SAP APIs. AI automation in this design reads the layer's data and proposes changes; approved writes reach the ERP through fixed, reviewed routes.
- **Licensing remains the organization's responsibility.** Get a licensing review before go-live, and treat SAP-originated data sent to AI tools separately.
- **Dynamics and other ERPs use the same routes.** The crosswalk, the signed records and the certificates don't change when the ERP does.

Where it runs, and who holds the keys

PART	RUNS IN	OWNED BY
Edge, consent gate, CA issuing worker	The organization's Cloudflare account	The organization
Certificates, revocations, signed records, crosswalk	The organization's Xano workspace	The organization
Root key	Offline or the organization's own key store	The organization only
Platform access	A scoped service token	Revocable by the organization at any time

The test for every part: if the platform team's access were revoked tomorrow, the CA, the records and the routes keep working from the organization's own accounts.

Status

PART	STATUS
Certificate Transparency and domain monitoring (trust watch)	Live
Consent and release gate at the edge	Live
Private CA template, signed transaction records	In review, available to pilot customers
Plugin and connector offload	Built per customer, one plugin at a time

Related

- Certificates, PKI tokens and the data release
- Keep the castle. Distribute the gold.
- Sources: SAP v Diageo, Computer Weekly; SAP API Policy version 4, The Register; Shopify app token deadlines; Google Merchant API product changes